

S BHANU PRAKASH

Cybersecurity Enthusiast — Ethical Hacking & VAPT Practice

Nmap Network Scan Report

Reconnaissance & Service Enumeration — Metasploitable2 Lab VM

Target	Metasploitable2 (intentionally vulnerable lab VM)
Target IP	192.168.44.132 (isolated virtual lab network)
Attacker Host	Kali Linux
Tool Used	Nmap 7.99
Command	nmap -A 192.168.44.132
Scan Date	12 July 2026
Purpose	Independent practice — network reconnaissance & service enumeration skills

Note: This assessment was carried out in an isolated personal/virtual lab environment against intentionally vulnerable practice systems, as part of independent cybersecurity skill-building. No production systems, third-party assets, or real organizations were involved or affected.

1. Objective

The objective of this exercise was to perform an active network reconnaissance scan against the Metasploitable2 lab virtual machine using Nmap, to practice host discovery, port scanning, service/version detection, OS fingerprinting, and NSE script scanning — core skills used during the reconnaissance phase of a penetration test.

2. Scan Overview

Field	Value
Target IP	192.168.44.132
Scanner	Kali Linux (Nmap 7.99)
Command	nmap -A 192.168.44.132
Scan Duration	73.90 seconds
Host Status	Up (latency 0.00096s)
Ports Scanned	1000 default top ports — 977 closed, 23 open
Detected OS	Linux 2.6.9 – 2.6.33
Network Distance	1 hop

The -A flag enabled OS detection, service/version detection, NSE default script scanning, and traceroute in a single pass.

3. Open Ports & Services Identified

Port	Proto	Service	Version / Notes
21	tcp	ftp	vsftpd 2.3.4 — anonymous login allowed
22	tcp	ssh	OpenSSH 4.7p1 Debian 8ubuntu1
23	tcp	telnet	Linux telnetd — unencrypted remote login
25	tcp	smtp	Postfix smtpd — legacy SSLv2, weak ciphers
53	tcp	domain	ISC BIND 9.4.2
80	tcp	http	Apache 2.2.8 (Ubuntu) DAV/2 — "Metasploitable2 - Linux"
111	tcp	rpcbind	Exposes NFS, mountd, nlockmgr, status
139/445	tcp	netbios-ssn	Samba smbd 3.0.20-Debian — SMB signing disabled
512	tcp	exec	rexec service
513	tcp	login	rlogin service
514	tcp	shell	rsh-like shell service
1099	tcp	java-rmi	GNU Classpath grmiregistry
1524	tcp	bindshell	"Metasploitable root shell" — pre-configured backdoor
2049	tcp	nfs	NFS v2-4
2121	tcp	ftp	ProFTPD 1.3.1

Port	Proto	Service	Version / Notes
3306	tcp	mysql	MySQL 5.0.51a-3ubuntu5
5432	tcp	postgresql	PostgreSQL 8.3.0–8.3.7, cert expired 2010
5900	tcp	vnc	VNC protocol 3.3 — VNC auth only
6000	tcp	X11	Access denied on probe
6667	tcp	irc	UnrealIRCd 3.2.8.1
8009	tcp	ajp13	Apache JServ Protocol v1.3
8180	tcp	http	Apache Tomcat/Coyote 1.1 — "Apache Tomcat/5.5"

4. Key Findings & Risk Indicators

- Anonymous FTP (port 21): vsftpd 2.3.4 permits anonymous login. This exact version is historically associated with a known backdoor vulnerability.
- Pre-configured bindshell (port 1524): Nmap fingerprinted this directly as a "Metasploitable root shell," indicating a deliberately planted backdoor listener.
- Plaintext protocols: Telnet (23), rlogin (513), and rexec (512) transmit credentials and data unencrypted.
- Weak/legacy TLS: SMTP (25) and PostgreSQL (5432) advertise SSLv2 with export-grade and RC4/DES ciphers; both use certificates that expired in 2010.
- Outdated service stack: Apache 2.2.8, Samba 3.0.20, MySQL 5.0.51a, ProFTPD 1.3.1, UnrealIRCd 3.2.8.1, and PostgreSQL 8.3.x all predate 2011 and carry numerous public CVEs.
- SMB misconfiguration: message signing disabled, guest access permitted.
- Exposed RPC/NFS surface: rpcbind (111) exposes NFS, mountd, and nlockmgr, widening the enumeration attack surface.
- Old kernel: OS fingerprinting places the host on the Linux 2.6.x kernel line (2.6.9–2.6.33), consistent with an intentionally outdated training distribution.
- Clock skew: mean clock skew of ~1 hour was reported, relevant to time-based authentication/logging analysis.

5. Overall Assessment

This host profile — anonymous FTP, an explicit "root shell" bindshell service, unencrypted admin protocols, unpatched decade-old service versions, and a self-identifying HTTP title of "Metasploitable2 - Linux" — is consistent with the intentionally vulnerable Metasploitable2 training VM rather than a production system. It is purpose-built to expose classic vulnerability classes (backdoors, weak authentication, outdated software, plaintext protocols) for hands-on lab practice.

What I practiced in this exercise

- Structuring and interpreting an aggressive Nmap scan (-A) covering OS/version/script detection.
- Reading service banners to identify outdated or vulnerable software versions.
- Recognizing indicators of deliberately planted backdoors vs. genuine misconfigurations.
- Prioritizing findings by exploitability, to plan a logical next phase of testing (FTP and bindshell for initial access, SMB/RPC/NFS for enumeration).